

MUSUBI PLATFORM

Musubi プラットフォーム 要件定義書

ローカル飲食店向け Web制作・公開・ネット予約・口コミ運用・集客レポートのサブスク事業システム

版数 v0.3（ドラフト）

作成日 2026-06-29

対象 事業システム全体（営業～運用）

位置づけ 確定・未決事項の整理

本書は IPA「非機能要求グレード」「機能要件の合意形成ガイド」の考え方に準拠して整理する。

本書の目的と位置づけ

- 目的：Musubi 事業を支えるシステム全体について、確定済みの要件と未確定の要件を可視化し、合意形成と今後の意思決定の土台とする。
- 対象範囲：営業（リード管理）→ 顧客サイトの制作・公開・予約 → 口コミ返信・月次レポート・月額課金までの一連の業務システム。
- 構成：管理アプリ(musubi-admin)・顧客ポータル(musubi-portal)・公開サイト群・定期処理・外部サービス連携。
- 読者：事業責任者・開発担当・運用担当・協業パートナー。

状態の凡例

確定：実装済み・合意済み

仕掛：実装途中／一部のみ

未確定：方針未決・外部依存

本書は現時点のスナップショット。決定に応じて改訂する。

OVERVIEW

事業・システム概要

- 事業：Google 評価は高いが自社サイト・ネット予約を持たない地域飲食店に、サイト制作（初期費）＋月額運用（保守・口コミ自動返信・月次レポート）をサブスクで提供。営業・制作の2名体制。
- システムの役割：①営業のリード管理、②サイトの制作・公開・予約、③口コミ返信の半自動化、④集客の月次レポート、⑤月額課金、をひとつの基盤で回す。
- 提供面：運用は管理アプリ、店舗オーナーは顧客ポータル、来店客は各店の公開サイトを使う。

技術基盤（確定）

- 管理/ポータル：Next.js 15 / Vercel
- データ：Supabase（DB・Storage・Auth）
- 公開サイト：Cloudflare Pages
- DNS：Cloudflare（musubiweb.com）
- AI：Anthropic Claude
- メール：Resend / 課金：Stripe
- 集客：GA4 / 口コミ：Google Business Profile

システム全体構成

管理アプリ（運営）

ダッシュボード
営業リスト(CRM)
顧客管理 / サイト制作
ネット予約 / 口コミ返信AI
請求 / コスト / レポート / 設定

顧客ポータル（店主）

口コミ承認
月次レポート閲覧
（オーナー向け閲覧/操作）

公開サイト（来店客）

店舗サイト（サブドメイン）
ネット予約フォーム
GA4 計測タグ

データ / 認証基盤

Supabase : stores / leads / reviews
reservations / reports / contracts
Auth (staff・owner) + RLS / Storage

定期処理・外部連携

Cron : 月次レポート集計 / コスト監視 / 口コミ下書き
GBP・GA4・Stripe・Resend・Cloudflare・Anthropic

STATUS

構築フェーズと進捗

Phase	内容	状態
0	基盤（各SaaS登録・GA4・OAuth・GBP API 申請）	確定
2	データ基盤・認証・営業リスト(CRM)・顧客ポータル	確定
3	サイト制作(ビルダー)・公開(Cloudflare Pages)・ネット予約	確定
4	月次レポート（GA4 集計・自動公開・通知）	確定
6	顧客ポータルの口コミ承認UI（本番実証済）	確定
7	監視・コストアラート・バックアップ復元	確定
5	課金・サブスク（Stripe）：コード完了・実テスト残	仕掛
1	口コミ自動返信の実店舗疎通：Google Business Profile API 承認待ち	未確定

律速：GBP API の利用承認が Phase 1（口コミ取得・自動返信の本番疎通）と Phase 6（実投稿）の前提。承認まで該当機能は手動代替。

SCOPE

対象範囲（スコープ）

対象に含む

- 営業リード管理（CRM・スコアリング）
- 顧客サイトの制作・公開・削除
- ネット予約（空き・予約・通知・管理）
- 口コミ返信の下書き生成・承認
- 月次集客レポート（GA4）
- 月額課金・サブスク（Stripe）
- 顧客ポータル・運用基盤（監視・コスト）

対象外 / 別途検討

- 予約の決済・前金（未確定）
- 来店客の予約変更・キャンセル（未確定）
- 顧客所有の独自ドメイン接続（未確定）
- テンプレートの多業種展開（仕掛）
- 問い合わせ内容のDB保存・CRM連携（未確定）
- 多言語・店舗横断の高度分析（未確定）
- GBP 以外の口コミ媒体（未確定）

GLOSSARY

用語定義

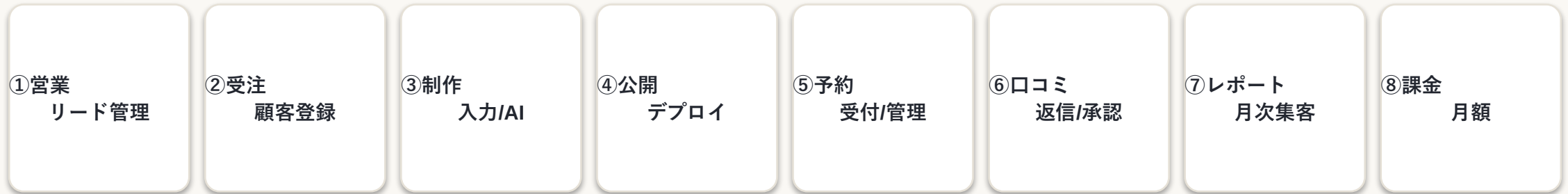
区分	用語 / 説明	状態
顧客	ストア（店舗）：契約先の飲食店。stores の1レコード。サイト・予約・レポートの単位。	確定
営業	リード：見込み客。leads で管理しスコア/ランクを自動算出。	確定
制作	テンプレート / content.json：サイトのひな型と1店舗分の内容データ。	確定
公開	デプロイ / サブドメイン：内容からHTML生成し <店舗>.musubiweb.com で公開。	確定
運用	口コミ下書き / 承認：AIが返信案を生成、店主がポータルで承認しGBPへ投稿。	仕掛
運用	月次レポート：GA4 から集計した集客指標を加工して提示。	確定

ACTORS

利用者と役割

ID	利用者 / 役割	状態
U1	運営スタッフ（Musubi）：営業・制作・公開・予約/口コミ/課金の運用。管理アプリ利用。	確定
U2	店舗オーナー（顧客）：口コミ承認・レポート閲覧。顧客ポータル利用。	確定
U3	来店客：公開サイトの閲覧・ネット予約。	確定
U4	店舗オーナーによるサイト自己編集・権限境界（マルチユーザー）	未確定
U5	協業パートナー（制作代行）の作業範囲・権限	未確定

業務要件（事業の流れ）



- ①②は営業・受注、③④は制作・公開、⑤～⑧は月額運用（予約・口コミ・レポート・課金）。人手を最小化して1人で多店舗を回すのが狙い。
- 目標：実店舗1件で「公開 → 口コミ自動返信 → 月次レポート → 月額課金」が一周すること（GBP API 承認が律速）。

機能要件 一覧①：営業・制作・公開・予約

ID	機能	状態
F1	ダッシュボード（KPI・タスク・未返信口コミの集約）	確定
F2	営業リスト(CRM)：リードCRUD・ステータス管理・スコア/ランク・CSV取込	確定
F3	顧客管理：店舗(stores)のCRUD	確定
F4	サイト制作：テンプレート選択・フォーム/JSON入力・画像アップロード・AI下書き・プレビュー	確定
F5	サイト公開：Cloudflare Pages デプロイ・サブドメイン割当・SSL・削除	確定
F6	ネット予約：空き状況・予約・確認/通知メール・予約管理（在庫型）	確定
F7	顧客独自ドメイン接続 / 来店客の予約変更・キャンセル	未確定

機能要件 一覧②：口コミ・レポート・課金・運用

ID	機能	状態
F8	口コミ返信AI：返信下書きの自動生成（Claude・インジェクション対策）	確定
F9	口コミ承認フロー：顧客ポータルで承認/編集/スキップ	確定
F10	口コミ取得・GBPへの実投稿（Google Business Profile 連携）	未確定
F11	月次レポート：GA4 集計・自動公開・オーナー通知	確定
F12	課金・サブスク：Stripe 3プラン・Webhook同期・初期費	仕掛
F13	顧客ポータル：オーナー向け（口コミ承認・レポート閲覧）	確定
F14	運用基盤：コスト監視・死活監視・バックアップ復元	確定
F15	認証・認可：Supabase Auth + RLS（運営/店主の分離）	確定

機能詳細：営業リスト・顧客管理

- 確定：リード(leads)を未着手→アポ→商談→受注/除外で管理。ランク/ステータスでフィルタ。CSV一括取込に対応。
- 確定：追加/編集/取込時にスコア・ランクを自動算出（営業の優先順位付け）。スタッフ限定のRLS。
- 確定：受注後は顧客（stores）として登録し、制作・公開・予約・レポート・課金の対象になる。
- 未確定：受注からの自動引き継ぎ（リード→ストア生成）の自動化範囲。

機能詳細：サイト制作・公開・ネット予約

- 確定：テンプレを選び、内容をフォーム/詳細JSONで編集。右ペインに即時プレビュー（編集箇所を強調）。画像はアップロード、AIは参考URL/テキストから各項目と画像候補を生成。
- 確定：管理画面から Cloudflare Pages へ公開、<店舗>.musubiweb.com を自動割当・SSL自動。公開サイトの削除も可能。
- 確定：来店客は空き状況を見て予約（在庫型・二重予約防止）。確定後に来店客/店舗へ通知メール。管理画面で予約一覧・取消。
- 仕掛/未確定：テンプレの多業種展開、独自ドメイン、来店客の予約変更・キャンセル、席種別/コース別の在庫精緻化。

機能詳細：口コミ返信AI

- 確定：口コミに対する返信の下書きを Claude が生成。低評価は要確認フラグ。プロンプトインジェクション対策（口コミを信頼境界外として扱う）・前置き除去・失敗時は人手確認に倒す。
- 確定：店舗オーナーが顧客ポータルで下書きを承認/編集/スキップ。承認は本人の店舗のみ（IDORガード）。
- 未確定（外部依存）：Google Business Profile API の利用承認待ち。承認後に「新着口コミの定期取得」「承認済みのGBP実投稿」「レポート連携」を有効化。

機能詳細：月次集客レポート

- 確定：GA4 から前月分を集計（1プロパティ集約・ホスト名で店舗識別）。アクセス数・電話タップ・予約数を店舗ごとに保存。
- 確定：毎月の定期処理で未公開分を自動公開し、店舗オーナーへ一度だけ通知（既公開は非破壊・二重通知なし）。顧客には生のGA4ではなく加工レポートのみ提示。
- 確定：認証は鍵レス（Workload Identity Federation）。本番で集計の実通しを確認済み。
- 仕掛：GBP由来の指標（口コミ件数等）は API 承認まで手入力代替。

機能詳細：課金・ポータル・運用基盤

区分	内容	状態
課金	Stripe 3プラン・初期費。Webhook で入金/失敗/解約をDB同期。金額はサーバ側固定・staff限定。	仕掛
課金	実テスト（契約→課金→失敗→解約の通し）・未入金フロー・領収書自動発行。	未確定
ポータル	店舗オーナー向け：口コミ承認・月次レポート閲覧。RLSで自店のみ。	確定
運用	コスト監視（上限80/100%アラート）・死活監視・論理バックアップ復元。	確定
認証	Supabase Auth + RLS。運営(staff)と店主(owner)を分離。	確定

非機能要件（IPA 非機能要求グレード 6大項目）

A. 可用性

稼働率・障害回復

B. 性能・拡張性

応答・処理量・拡張

C. 運用・保守性

監視・バックアップ・更新

D. 移行性

データ移行・並行稼働

E. セキュリティ

認証・データ保護・診断

F. システム環境・エコロジー

構成・コスト・環境

方針：マネージドSaaS中心の構成のため、各カテゴリの具体目標値（稼働率・性能・RPO/RTO・診断）は事業規模の確定後にグレード選択する。現状は未確定が多い。

非機能：可用性・性能拡張性

項目	内容	状態
A 可用性	Vercel/Cloudflare/Supabase のマネージド基盤を利用（各SLA準拠）。	確定
A 目標値	サービス目標稼働率・保守時間帯・障害復旧目標(RTO/RPO)。	未確定
B 応答性	プレビューはクライアント生成で即時。デプロイは数十秒。	確定
B 処理量	顧客数・同時公開・予約/口コミ/レポート処理のスケール目標と上限。	未確定
B 拡張	サーバレスで水平拡張。テンプレ追加・機能追加で拡張。	仕掛

非機能：運用保守性・移行性

項目	内容	状態
C CI/CD	GitHub push → Vercel 自動デプロイ。構築ログを随時記録。	確定
C 監視	死活監視(UptimeRobot)・コスト監視・障害ランブックを整備。	確定
C バックアップ	論理バックアップ復元手順あり。自動BU周期・正式RPOは未定。	仕掛
D 移行	デモ「さくら亭」をテンプレ化済。既存サイトからの取り込み範囲は未定。	仕掛
D 並行稼働	旧サイトとの切替・リダイレクト方針。	未確定

非機能：セキュリティ・システム環境

項目	内容	状態
E 認証/認可	Supabase Auth + RLS、staff/owner分離、IDOR対策・店舗スコープ。	確定
E 入出力	XSS（出力エスケープ・画像MIME制限）・SSRF対策・CORS限定・インジェクション対策。	確定
E 個人情報	予約者・顧客情報の取扱方針・保持期間・同意取得・特商法/プライバシー表記。	未確定
E 診断/監査	脆弱性診断・監査ログ・WAF の要否。	未確定
F 構成/コスト	マネージドSaaS・サーバレス。コスト監視あり、予算上限は未定。	仕掛

外部インターフェース・データ要件

外部サービス連携

- Cloudflare (Pages・DNS)
- Supabase (DB/Storage/Auth)
- Anthropic (AI生成) / Resend (メール)
- Stripe (課金)
- GA4 Data API (レポート・確定)
- Google Business Profile (口コミ・未確定)

主なデータ (Supabase)

- leads : 営業リード (確定)
- stores : 店舗・サイト内容 (確定)
- reservations : 予約 (確定) / reviews : 口コミ (確定)
- reports : 月次指標 (確定) / contracts : 契約 (確定)
- site-assets : アップロード画像 (確定)
- 保持期間・削除・エクスポート方針 (未確定)

CONSTRAINTS

制約条件・前提

- ドメイン musubiweb.com の DNS は Cloudflare 管理（移管済）。公開サイトのサブドメインはこれに依存。
- 公開サイトは静的HTML（サーバ処理なし）。動的処理は予約API・各種Cron・管理/ポータル側に集約。
- AI・メール・課金・レポート・公開は各SaaSのキー/環境変数に依存（本番Vercelへの設定が前提）。
- 口コミの本番運用（取得・自動返信・投稿）は Google Business Profile API の利用承認が前提（承認待ち）。
- 法令：予約者・顧客の個人情報、特商法表記、プライバシーポリシーの整備が前提（未対応）。

OPEN ISSUES

未決定事項 一覧（要協議）

ID	未決定事項	区分
O1	GBP API 承認後の口コミ取得・自動返信・実投稿の本番疎通（Phase 1/6 の律速）	未確定
O2	課金の実テスト・未入金フロー・領収書自動発行	仕掛
O3	店舗オーナーのサイト自己編集・マルチユーザー権限境界（RLS）	未確定
O4	来店客の予約変更/キャンセル・リマインド・席種別在庫	未確定
O5	顧客独自ドメイン接続・ステージング環境	未確定
O6	個人情報の取扱方針・保持期間・特商法/プライバシー表記	未確定
O7	非機能の目標値（稼働率・性能・RPO/RTO・診断/監査・予算上限）	未確定
O8	テンプレート多業種展開の範囲・優先順位	仕掛

ADDENDUM

検討漏れ・追加論点（多観点レビュー）

法務／セキュリティ／運用(SRE)／事業／UX・SEO／データの6観点で専門レビューを実施し、まだ要件化されていない論点・リスクを抽出した（セキュリティは実コードで裏付け）。横断的に特に重大な6点を以下に示す。

#	横断的に重大なリスク（複数観点で共通指摘）	優先
R1	公開予約APIが service_role 直結・無認証・CORS全開で、レート制限/CAPTCHA/幂等なし → 榨枯渴・確認メール乱発・なりすまし	高
R2	RLS が reservations 以外コード化されておらず、店舗間データ分離が未検証 → 他店の個人情報を閲覧できる横断漏えい	高
R3	課金⇄公開/予約/口コミの自動連動がなく、Cron・Stripe webhook の無音故障対策もない → 収益逸失・誤って無料提供	高
R4	レポートの時系列スナップショット欠如+ホスト名での店舗識別が脆く、指標が再現不能・サイレント誤集計	高
R5	法令の土台未整備（管理者/委託先の立場・契約書面・電通法の外部送信規律・営業メールのオプトイン）	高
R6	運用が2名でバス係数1、SLO/RTO/RPO 未定義 → 障害時に復旧不能・長期化	高

検討漏れ：法令・コンプライアンス

#	論点 → 推奨対応	優先
L1	電通法の外部送信規律(2023)：GA4等の外部送信ポリシー公表を全店サイトに義務 → テンプレ標準装備	高
L2	個人情報の立場整理：店舗=管理者／Musubi=委託先 を確定し委託契約(DPA)を締結	高
L3	営業メールはオプトインが原則(特電法)：同意経路に限定・配信停止/送信者表示・取引メールと系統分離	高
L4	越境移転：海外SaaSの所在国・保護措置の情報提供、SCC/DPA、委託先管理台帳	高
L5	契約書面：利用規約・サブスク約款(自動更新/中途解約料/サイト所有権)・プライバシーポリシー雛形・SLA	高
L6	制作物の表記責任(景表法/特商法/食品表示)：店舗の最終承認・免責/表明保証を契約に明記	高
L7	AI口コミ返信：必ず店主承認後に投稿・代理権限の書面・虚偽の確約を禁止(ステマ規制/GBP規約)	高
L8	予約者/口コミの保持期間・開示/削除請求の窓口、要配慮情報(アレルギー)・未成年同意、画像の権利	中

検討漏れ：セキュリティ・プライバシー

#	論点 → 推奨対応	優先
S1	公開予約APIの多層防御：レート制限・CAPTCHA(Turnstile)・冪等キー/重複拒否・WAF・確定前のメール検証	高
S2	全テーブルのRLSをマイグレーションでコード化+テナント分離の自動テスト(別オーナーJWTで0件)	高
S3	シークレット管理：ルートで **/.env 一括ignore・検証にliveキーを使わない・restricted key・ローテ・CIスキャン	高
S4	サブドメイン乗っ取り対策：削除をトランザクシヨンのに・DNS ↔ Pages の整合チェック(reconciliation)	中
S5	監査ログ(誰が予約/課金/公開削除/口コミ投稿を変更)を append-only で記録	中
S6	PII最小化・列暗号化(pgcrypto)・保持TTL/purge、Storageは公開/非公開バケット分離・署名URL	中
S7	メール：ダブルオプトイン/MX検証・DMARC段階適用・バウンス監視、DNS rebinding(TOCTOU)遮断	中
S8	全Server Actionで認可(staff/owner-scope)を強制する共通ラッパ+テスト、依存脆弱性スキャンのCIゲート	中

検討漏れ：信頼性・運用（SRE）

#	論点 → 推奨対応	優先
O1	コンポーネント別SLO(公開サイト/予約API/管理)とエラーバジェット、RTO/RPO数値化・PITR確保・復元演習	高
O2	Cronの無音故障対策：死亡通知型監視(Healthchecks等)・幂等・再実行・実行ログ(対象期間/件数)	高
O3	Stripe webhook整合：幂等・失敗の再処理・日次でStripe ↔ DB突合・失敗アラート	高
O4	タイムゾーン統一：UTC保存/JST導出、月次集計境界をJST固定(GA4プロパティTZ含む)	高
O5	予約の状態機械(仮→確定→来店/キャンセル/No-show)・同時実行の原子化・キャパ変更の遡及検証	高
O6	デプロイ失敗のロールバック(Instant Rollback)・公開前の確認/承認・デプロイ後スモークテスト	高
O7	バス係数1の解消：ランブック/台帳/全SaaSアクセスの2名共有・外部エスカレーション先の確保	高
O8	メール到達(SPF/DKIM/DMARC・bounce処理)、SaaS障害時の縮退、無料枠上限の監視と移行閾値、サポート窓口SLA	中

検討漏れ：データ・アーキテクチャ

#	論点 → 推奨対応	優先
D1	レポートの時系列スナップショット(MRR/契約推移を追記型・GA4再集計は版管理)=過去断面を失わない	高
D2	ホスト名による店舗識別の堅牢化:hostnameエイリアス表・正規化(www/大小)・未マッチ検知アラート	高
D3	在庫モデルの拡張:営業時間ルール+例外日(休業/特別)+枠(slot)+リソース種別(席種/コース)を分離	高
D4	content(jsonb)の schema_version・投入バリデーション・テンプレ更新時の既存サイト追従	高
D5	外部IDの集約(store_integrations: provider/external_id/逆引き)、リード→ストアのID対応(lead_id)	高
D6	予約の一意性・冪等・排他制約(同一枠の確定上限をDB制約で担保)	高
D7	参照整合性:原則ソフトデリート・子はON DELETE RESTRICT(売上/契約/予約の証跡保持)	高
D8	GA4指標の定義(イベント/CV条件)・bot/内部除外・重複防止、マスタ(プラン/席種/コース)化と価格スナップショット	中

検討漏れ：公開サイト・予約UX・SEO

#	論点 → 推奨対応	優先
X1	満席時の代替提示(近接日/別時間帯/電話導線)＝最も意欲の高い客の離脱を防止	高
X2	営業時間/定休/特別営業の単一ソース管理(サイト・schema・予約・GBP を一致)	高
X3	構造化データ(schema.org Restaurant：営業時間/住所/geo/menu/acceptsReservations)を自動生成	高
X4	重複コンテンツ対策：canonical固定・テンプレ/未公開はnoindex・sitemap自動・ルートに店舗ハブ	高
X5	画像最適化/CWV(WebP/AVIF・srcset・遅延・寸法でCLS防止・font-display)、モバイル追従CTA(電話/予約/地図)	高
X6	予約フォームの入力検証・二重送信防止・エラー時挙動・入力保持、問い合わせ/予約の送信先DB保存＋スパム対策	高
X7	予約の確認/前日リマインド・HTMLメール可読性、予約カレンダーのa11y(キーボード/ARIA/色以外の状態)	中
X8	テンプレのコントラスト保証・alt入力促し、多言語(英＋hreflang)、OGP/SNSカード自動生成	中

検討漏れ：事業・課金・解約

#	論点 → 推奨対応	優先
B1	課金⇔プロビジョニングの状態機械(trial/active/past_due/canceled → 公開/予約/口コミのON/OFF自動・段階停止)	高
B2	集客効果の因果KPI：公開前ベースライン取得・CV計測・回収ライン達成度を月次レポートに常設	高
B3	解約オフボーディング：成果物(HTML/画像/データ)の引き渡し・サブドメイン回収/301=「資産が残る」と整合	高
B4	口コミ承認運用：★1〜3は人間レビュー必須・自動投稿しない・期限切れは保留・承認代行オプション	高
B5	プラン別ゲーティング(機能出し分け・更新回数カウンタ・上限超過のアップセル導線)	中
B6	情報正確性の責任分界、営業情報の即時更新は回数制限外、オンボーディング素材回収期限・仕掛け可視化	中
B7	多店舗/チェーン対応(オーナーと店舗を分離・複数店切替・請求まとめ)、GBP所有権の境界(オーナー権限維持)	中
B8	価格改定/日割り/初期費返金/最低契約期間の規定確定、紹介の仕組み、テンプレ業種展開の優先(飲食固定)	中

追加論点の優先対応（提案）

短期：設計と不可分（先に固める）

- 予約APIの多層防御（レート制限/CAPTCHA/冪等）
- 全RLSのコード化＋テナント分離テスト
- 課金⇄公開/予約の状態機械（自動連動）
- レポートの時系列スナップショット設計
- タイムゾーン統一（UTC保存/JST境界）
- シークレット一括ignore・restrictedキー

中期：体制・品質を整える

- 契約・法令の文書群（規約/DPA/外部送信）
- SLO/RTO・PITR・Cron/Stripe監視と突合
- 在庫モデル拡張・ホスト名エイリアス
- 公開サイトのSEO/構造化データ/CWV/満席代替
- 解約オフボーディング・データ可搬性
- バス係数1の解消（手順/台帳/権限の共有）

注：個人情報・保持期間・なりすまし対策・バックアップ暗号化は法令確定を待たず、技術設計の前提として先行して織り込む。

NEXT

今後の進め方

- ①GBP API 承認の取得を最優先（口コミ運用＝事業の差別化機能の律速）。
- ②課金(Phase 5)の実テストを通し、未入金・領収書フローを確定する。
- ③個人情報・法令対応（予約者/顧客情報）を公開拡大の前提として早期に方針決定。
- ④非機能は事業規模の見込みが立った段階で IPA グレードを選び目標値を確定。
- ⑤確定要件は本書ベースで実装・検証を継続。改訂は版数を上げて管理する。

改訂履歴：v0.1（builder/予約）→ v0.2（事業システム全体）→ v0.3（2026-06-29 多観点レビューで検討漏れ・追加論点を追補）。